

Vulnerability Assessment Report

1st January 20XX

System Description

The system being assessed is a remote database server used by an e-commerce company. The server supports employees who work remotely around the world and allows them to query information about potential customers. The server uses a powerful CPU, 128 GB of RAM, a current Linux operating system, and MySQL for database management. It communicates over an IPv4 network and uses SSL/TLS to protect network communications. However, the database server has been publicly accessible since the company launched three years ago, creating a significant security vulnerability.

Scope

This vulnerability assessment focuses on the database server's current access controls and the risks associated with its public accessibility. The assessment considers a three-month period from June through August 20XX. NIST SP 800-30 Rev. 1 is used as the primary framework for identifying threat sources, threat events, likelihood, severity, and overall risk.

Purpose

The database server is valuable because it allows employees around the world to access information needed to support the company's e-commerce operations and interact with potential customers. Protecting the information stored on the server is important because unauthorized access, modification, or loss of data could affect business operations and customer trust. If the server were disabled, employees could lose access to important customer information and experience disruptions in their daily responsibilities. Securing the server can reduce the likelihood and impact of these risks.

Risk Assessment

Threat source	Threat event	Likelihood	Severity	Risk
Outsider / Hacker	Perform reconnaissance and surveillance of the organization	3	2	6
Group / Competitor	Obtain sensitive information via exfiltration	2	3	6
Standard User	Alter or delete critical information	2	3	6

Risk Calculation

Risk is calculated by multiplying likelihood by severity:

Risk = Likelihood × Severity

- Outsider/Hacker: $3 \times 2 = 6$
- Competitor: $2 \times 3 = 6$
- Standard User: $2 \times 3 = 6$

The assessment uses the NIST qualitative scale, where 3 represents high, 2 represents moderate, and 1 represents low likelihood or severity.

Approach

This assessment uses a qualitative risk-assessment approach based on the likelihood and potential business impact of each threat event. The three threat sources were selected because the database is publicly accessible and is used to support business operations involving potential customer information. The selected threat events represent reconnaissance, unauthorized information access, and unauthorized modification or deletion of critical data. These risks are significant because successful attacks could expose information, disrupt employee access, or affect the company's ability to conduct normal operations.

Remediation Strategy

The company should restrict database access to authorized users and systems instead of leaving the server publicly accessible. Authentication should require strong passwords and multi-factor authentication, while role-based access control and least

privilege should limit users to only the information and functions required for their jobs. The company should also use auditing and monitoring to detect suspicious activity, maintain TLS for protected communications, and use IP allow-listing to restrict connections to approved corporate locations or systems. These controls provide multiple layers of protection against unauthorized access and data loss.

Conclusion

The database server presents a significant security risk because it has remained publicly accessible while supporting important business operations. The assessment identified external hackers, competitors, and unauthorized or compromised users as potential threat sources and evaluated reconnaissance, data exfiltration, and data modification or deletion as relevant threat events. Implementing stronger access controls, multi-factor authentication, least privilege, monitoring, and network restrictions can reduce the likelihood of unauthorized access and limit the potential impact on business operations.